

Learn Cryptocurrency: Beginner's Guide

Lesson 7: Security Best Practices

Security Best Practices - Study Notes

Key Concepts

1. **Two Factor Authentication (2FA)** – Adding a second verification step beyond a password.
2. **Hardware Wallets** – Physical devices that store private keys offline.
3. **Phishing Awareness** – Recognizing and avoiding malicious attempts to steal credentials.
4. **Secure Storage & Backup** – Protecting keys, passwords, and recovery phrases.
5. **Least Privilege Principle** – Giving users only the access they need.

Summary

Security best practices are essential for protecting digital assets, especially in the crypto and online services space. The cornerstone is **Two Factor Authentication (2FA)**, which significantly reduces the risk of unauthorized access by requiring something you know (password) and something you have (token, phone, app). **Hardware wallets** take this a step further by keeping private keys offline, making them immune to malware that could compromise computer systems.

Equally important is vigilance against **phishing**. Attackers often lure users into giving away credentials or private keys through fake login pages or malicious links. By checking URLs, using email filters, and verifying sender authenticity, users can avoid falling victim. Finally, **secure storage**—using encrypted vaults, backups on separate media, and mnemonic phrases stored offline—ensures that even if a device is lost or stolen, the assets remain safe.

Important Points

- **Enable 2FA on every account** that offers it; use authenticator apps or hardware keys (YubiKey, Duo, etc.).
- **Prefer hardware wallets** (Ledger, Trezor, KeepKey) for storing significant crypto holdings; never keep large balances on exchanges.
- **Never click links in unsolicited emails**; always type URLs manually or use bookmarks.
- **Verify URLs**: look for HTTPS, correct domain names, and the lock icon in the browser.
- **Store recovery phrases in a fire proof, waterproof safe**; consider splitting the phrase across multiple locations (the “shamir secret sharing” approach).
- **Use strong, unique passwords** for each service; consider a password manager (1Password, Bitwarden).
- **Regularly update software** and apply security patches to all devices.
- **Enable account notifications** for login attempts from new devices or locations.
- **Educate yourself on social engineering tactics**; the more you know, the less likely you’ll be tricked.

Examples

1. ****Hardware Wallet Setup****

You receive a new Ledger Nano X. During setup, you create a 24 word recovery phrase and store it in a safe. You then transfer 0.5 BTC from an exchange to the Ledger. Even if your computer gets infected with ransomware, the BTC remains secure because the private key never leaves the device.

2. ****Phishing Email Detection****

An email claims your bank account was compromised and asks you to log in via a link. The link points to `https://bank.com/secure-login`. You notice the domain is `bank.com`, but the official bank uses `https://secure.bank.com`. By verifying the domain and using the bank's official app, you avoid a credential stealing attack.

Quick Review

1. What is the main benefit of enabling 2FA on an account?
2. Name two hardware wallets commonly used for crypto storage.
3. List three signs that an email might be a phishing attempt.
4. Why is it risky to store your recovery phrase on a cloud service?
5. What does the "least privilege principle" mean in the context of account security?

Further Reading

- ****Multi Factor Authentication (MFA) Types**** – Authenticator apps, SMS, hardware keys, biometrics.
- ****Shamir Secret Sharing**** – Splitting recovery phrases into multiple parts.
- ****Cold Storage vs. Hot Wallets**** – When to keep assets online or offline.
- ****Social Engineering Tactics**** – Common scams and how to counter them.
- ****Password Manager Best Practices**** – How to choose, set up, and secure a vault.

Happy studying, and stay secure!

